

Security+ 2.1 · Threat Actors

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.1 — Threat Actors (10:23)** ·

[Vídeo no YouTube ↗](#)

Resumo da Aula: Quem ataca e POR QUÊ: nation-state (governo — espionagem/sabotagem, recursos enorme — APT); organized crime (lucro — ransomware, credential theft); hacktivist (ideologia — Anonymous); insider (dentro da casa — intencional ou descuidado); script kiddie (usa exploit pronto, volume); shadow IT (aplicação não-oficial que vira porta de entrada); competidor (industrial espionage).

💡 Highlights que a prova cobra

- APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo
- Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar
- Script kiddie: usa exploit pronto — volume, pouca sofisticação
- Insider: o maior risco por já estar DENTRO da confiança

🎯 Dicas de prova & Cenários Típicos

- 'motivated by political/social ideology' = hacktivist
- 'long-term, nation-state, persistent' = APT

Cenário clássico de exame: Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 2.1)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Threat Actors) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Atores de Ameaça (Threat Actors): Nation-state / APT (Advanced Persistent Threat):** altamente financiado, sofisticado, motivado por espionagem geopolítica a longo prazo. **Cybercriminal:** motivado por lucro financeiro direto (ransomware, extorsão). **Hacktivist:** motivado por causas políticas ou ideológicas. **Insider Threat:** funcionário ou terceiro com acesso legítimo que abusa de privilégios por dolo ou negligência.
- **Engenharia Social e Variantes de Phishing:** **Phishing:** campanha em massa por e-mail. **Spear Phishing:** ataque direcionado a indivíduo ou empresa específica usando dados de OSINT. **Whaling:** direcionado a executivos do C-level (CEO, CFO). **Vishing:** phishing por voz/telefone. **Smishing:** phishing por SMS. **BEC (Business Email Compromise):** impersonação de diretoria para desvio de faturas ou transferências bancárias.
- **Tipos de Malware e Vetores de Ataque:**
 - *Ransomware:* cifra dados corporativos e exige resgate em criptomoeda.
 - *Trojan:* software aparentemente inofensivo que instala backdoors ocultos.
 - *Rootkit:* modifica o kernel do sistema operacional e se oculta de ferramentas antivírus comuns.
 - *Worm:* malware autorreplicável que se propaga sozinho pela rede sem intervenção humana.
- **Vulnerabilidades de Aplicação (OWASP Top 10):**
 - *SQL Injection (SQLi):* manipulação de queries de banco de dados por falta de sanitização/parametrização (prepared statements).
 - *XSS (Cross-Site Scripting):* injeção de scripts maliciosos (JavaScript) no navegador da vítima.
 - *CSRF (Cross-Site Request Forgery):* induz a vítima logada a executar ações indesejadas em uma aplicação web confiável.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- Phishing não é mitigado apenas por filtros de e-mail; o controle humano fundamental é a simulação periódica de phishing e conscientização.
- Rootkits operam no nível de anel de privilégio (Ring 0 / Kernel), exigindo verificação de Secure Boot (TPM) para prevenção confiável.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?

- A)** Firewall mal configurado
- B)** Phishing + VPN sem MFA / credencial vazada
- C)** Cabo de rede exposto
- D)** Falta de antivírus

3. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

4. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: APT (Advanced Persistent Threat): government-backed — recursos enormes, tar...

5. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Organized crime = dinheiro; hacktivist = ideologia; nation-state = política...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Script kiddie: usa exploit pronto — volume, pouca sofisticação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Script kiddie: usa exploit pronto — volume, pouca sofisticação...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Insider: o maior risco por já estar DENTRO da confiança'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Insider: o maior risco por já estar DENTRO da confiança...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: "motivated by political/social ideology" = hacktivist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'motivated by political/social ideology' = hacktivist...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: "long-term, nation-state, persistent" = APT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'long-term, nation-state, persistent' = APT...

10. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário típico: 'um grupo financiado por governo espiona infra-critical por...

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — BEC / CEO fraud (fraude do CEO).

✓ **Por que está certa:** BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta.

✗ **Por que as outras estão erradas:**

- *Whaling*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Vishing*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Tailgating*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) B — Phishing + VPN sem MFA / credencial vazada.

✓ **Por que está certa:** A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1.

✗ **Por que as outras estão erradas:**

- *Firewall mal configurado*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Cabo de rede exposto*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Falta de antivírus*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista.

✗ **Por que as outras estão erradas:**

- *Instalar, Atualizar, Testar, Auditar, Arquivar*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Planejar, Fazer, Checar, Agir, Revisar*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Prevenir, Punir, Prever, Provar, Publicar*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) D — Implementar a solução correspondente: APT (Advanced Persistent Threat): government-backed — recursos enormes, tar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: Organized crime = dinheiro; hacktivist = ideologia; nation-state = política....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Script kiddie: usa exploit pronto — volume, pouca sofisticação....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Script kiddie: usa exploit pronto — volume, pouca sofisticação.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Insider: o maior risco por já estar DENTRO da confiança....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Insider: o maior risco por já estar DENTRO da confiança.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: 'motivated by political/social ideology' = hacktivist....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): 'motivated by political/social ideology' = hacktivist.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'long-term, nation-state, persistent' = APT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): 'long-term, nation-state, persistent' = APT.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Cenário típico: 'um grupo financiado por governo espiona infra-critical por....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.